Top 5 AI Agent Security Risks

Reviewed: 14 October 2026

01 / Permissions & identities

☐ Risk 1: Excessive tool permissions. Give each tool a narrow identity; keep sensitive actions behind approval. Test that a read-only task cannot write.

☐ Risk 2: Weak or shared identities. Block weak passwords, use appropriate MFA and rotate exposed secrets. Test revocation using a synthetic account.

Record the evidence

Item / owner	Evidence / next action

02 / Untrusted input & retrieval

☐ Risk 3: Prompt injection and data exfiltration. Treat documents, web pages and email as untrusted. Separate instructions from data; constrain tool destinations. Test benign adversarial content in a safe environment.

☐ Risk 4: Retrieval leaks across roles or tenants. Enforce permissions before retrieval and before tool execution. Test the same question as an authorised and an unauthorised user.

Record the evidence

Item / owner	Evidence / next action

03 / Actions & recovery

☐ Risk 5: Unbounded actions or cost. Set limits, monitor actions, require approval and define a stop path. Test a deliberately over-limit request using synthetic data.

☐ Record each test: allowed action, denied action, observed result, owner, date and next step. A good answer alone does not prove a safe agent.

☐ Start with one workflow. Expand access only when the controls are demonstrated.

Record the evidence

Item / owner	Evidence / next action

Your next step

Bring one concrete decision to the €490 AI Decision Review. Scope, timing and applicable VAT are agreed before acceptance. No purchase or appointment is confirmed by a form.

sundaibot.com/ai-decision-review/

Guidance, not certification or legal advice. Confirm applicability and current law for your system.

Reviewed: 14 October 2026

OWASP · authentication guidance

https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html

NIST SP 800-63B-4 · passwords

https://pages.nist.gov/800-63-4/sp800-63b/passwords/

Datatilsynet · security risk assessment

https://www.datatilsynet.dk/regler-og-vejledning/behandlingssikkerhed/risikovurdering

GDPR · official EUR-Lex

https://eur-lex.europa.eu/eli/reg/2016/679/oj

Contact: eririmo@protonmail.com · UK company 13813344